

《信息系统安全》第四讲

安全风险评估

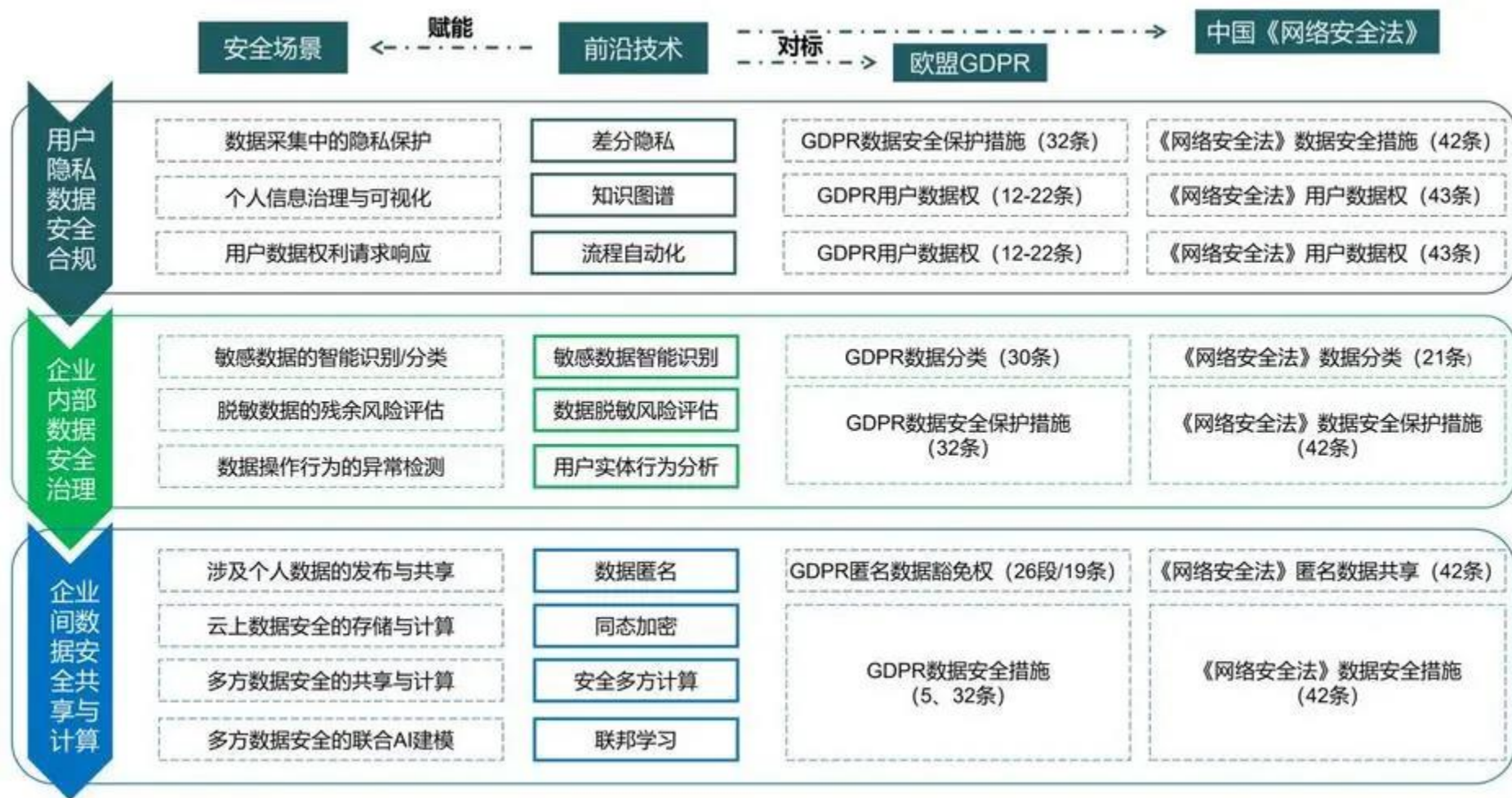
2024年10月22日

周亚建

yajian@bupt.edu.cn

Overview of Last Class

安全需求和安全策略（以数据安全为例）

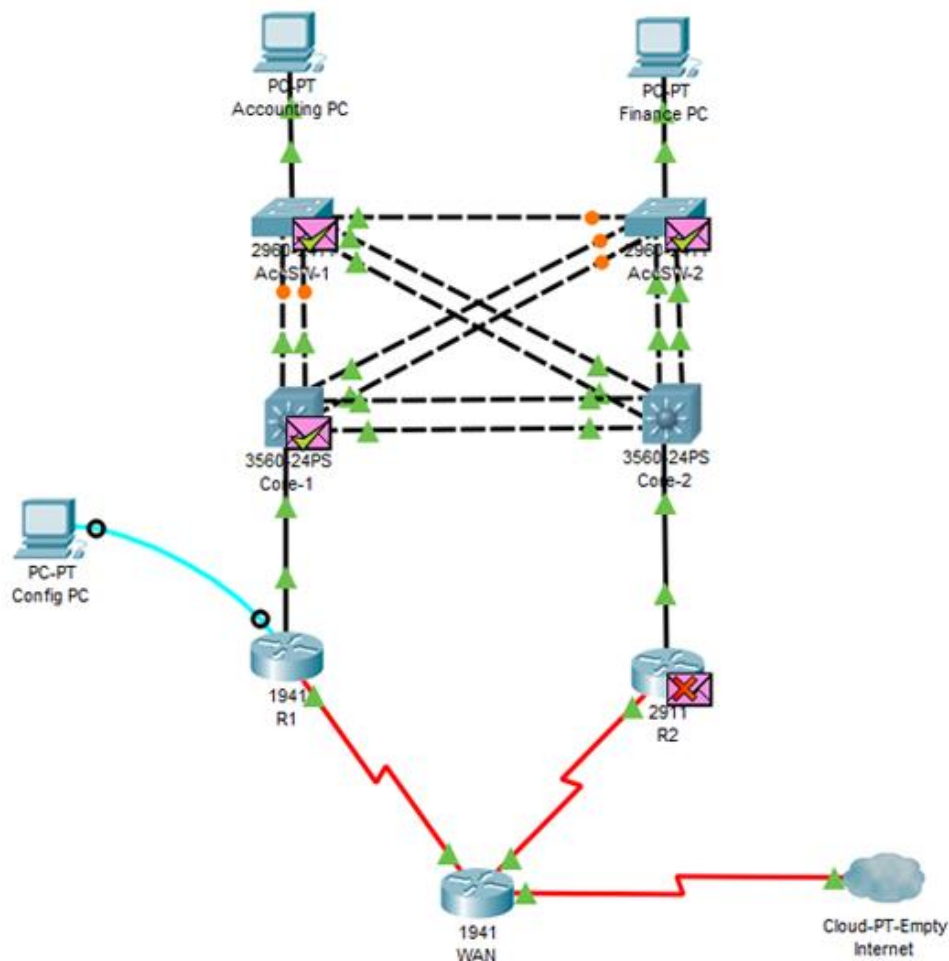


Overview of Last Class

纸上得来终觉浅，
绝知此事要躬行。

使用网络模拟器：ENSP PRO or Cisco Packet Tracer

——陆游·《冬夜读书示子聿》



Simulation Panel

Event List

Vis.	Time(sec)	Last Device	At Device	Type
	1.007	--	Core-2	STP
Visible	1.008	Core-2	Core-1	STP
Visible	1.008	Core-2	AccSW-2	STP
Visible	1.008	Core-2	R2	STP
Visible	1.008	Core-2	AccSW-1	STP

Reset Simulation ☒ Constant Delay Captured to: 1.008 s

Play Controls

Navigation buttons: Previous, Play, Next

本次课程的任务：曲突徙薪带给我们的启示



客有过主人者，见其灶直突，傍有积薪。客谓主人曰：“更为曲突远徙其薪不者将有火患。”主人嘿然不应。居无几何，家果失火。邻里共救之，幸而得息。于是杀牛置酒，谢其邻人，燔发灼烂者在上行，余各以功次坐，而不录言曲突者。人谓主人曰：“乡使听客之言，不费牛酒，终亡火患。今论功而请宾，曲突徙薪亡恩泽，焦头烂额为上客耶？”主人乃寤而请之。

——《汉书·霍光金日磾传》

信息系统中是否存在需要曲的“突”、徙的“薪”？

本次课程的任务

随着疫情、自然灾害和网络犯罪继续影响我们的世界，**唯一可以确定的是没有什么确定的**。因此，有必要保持高度的“警惕”，并为任何类型的服务中断做好准备。

信息系统安全是指信息系统的硬件、软件及其系统中的数据受到保护，不受偶然的或者恶意的原因而遭到破坏、更改、泄露，**系统连续可靠正常地运行，信息服务不中断**。



如何能做到

在信息系统投入使用之前后者在使用过程中，能否对系统存在的安全风险进行预警，以便提前做好应对策略。

本次课程的任务

信息系统由于可能存在的系统设计缺陷、隐含于软硬件设备的缺陷、系统集成时带来的缺陷，以及可能存在的某些管理薄弱环节，尤其当信息系统中拥有极为重要的信息资产时，都将使得面临复杂环境的信息系统潜在着若干不同程度的不确定性。

我们必须寻找任何会产生与组织目标相关的不确定性或与预期产生偏差的事物

- 不能仅仅停留在技术层面
- 甚至包括声誉、政治变化和气候变化的影响等。



风险和风险评估

本次课程的任务

故国虽大，好战必亡；天下虽安，忘战必危。——《司马法·仁本》

“居安思危，思则有备，有备无患。——《左传·襄公十一年》

什么是安全风险评估

对信息系统整体安全态势的感知和对重大安全事件的预警，实现“事前能预防，事中能控制，事后能处理”。

ISO/IEC 13335-1:2004

Information technology — Security techniques — Management of information and communications technology security — Part 1: Concepts and models for information and communications technology security management

<https://www.iso.org/standard/39066.html>

风险评估涉及标准

ICS 35.040
L 80



中华人民共和国国家标准

GB/T 20984—2007

信息安全技术
信息安全风险评估规范

Information security technology—

Risk assessment specification for information security

INTERNATIONAL
STANDARD

ISO/IEC
13335-1

First edition
2004-11-15

**Information technology — Security
techniques — Management
of information and communications
technology security —**

**Part 1:
Concepts and models for information and
communications technology security
management**

*Technologies de l'information — Techniques de sécurité — Gestion de
la sécurité des technologies de l'information et des communications —*

*Partie 1: Concepts et modèles pour la gestion de la sécurité des
technologies de l'information et des communications*

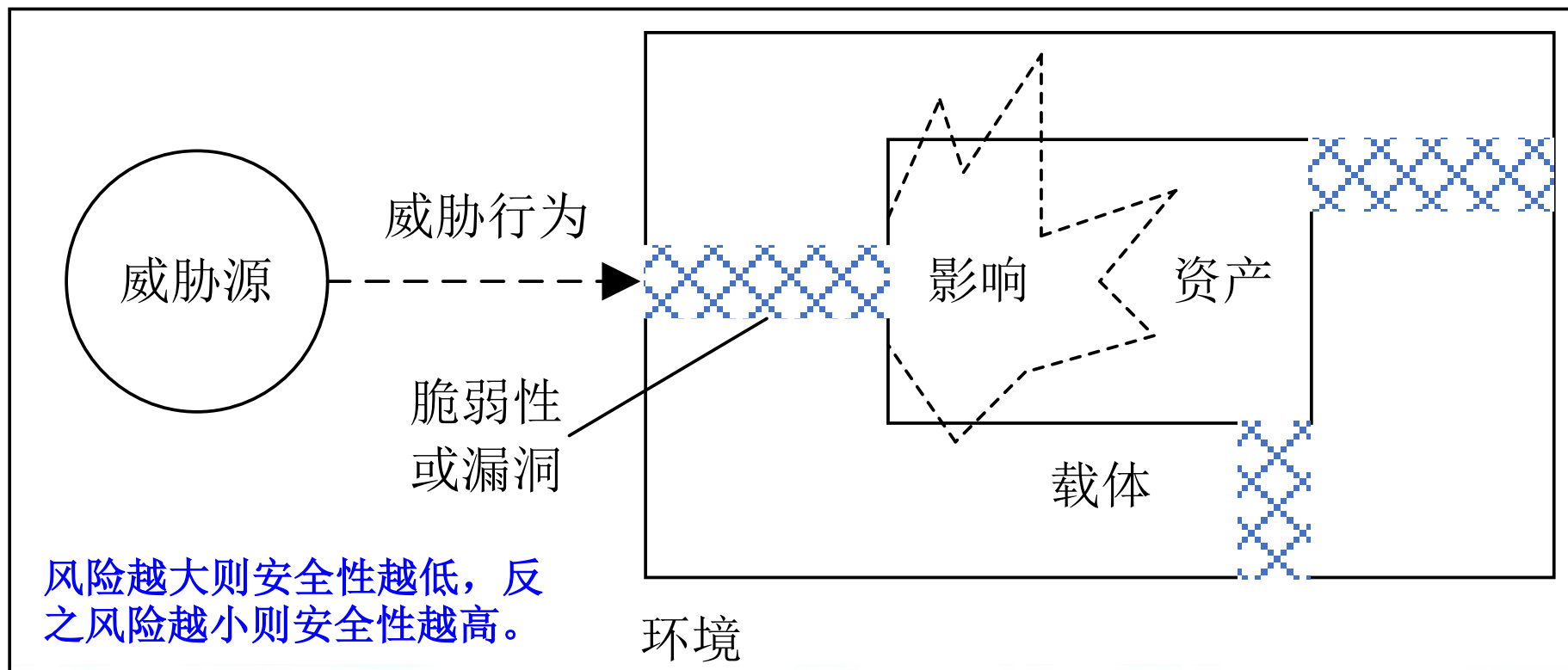
2007-06-14 发布

2007-11-01 实施

中华人民共和国国家质量监督检验检疫总局 发布
中国国家标准化管理委员会

风险（Risk）的概念

风险指在某一特定环境下，在某一特定时间段内，特定的威胁利用资产的一种或一组薄弱点，导致资产的丢失或损害的潜在可能性，即特定威胁事件发生的可能性与后果的结合。



风险就是信息系统安全的一个测度。

风险评估通俗类比

资产



威胁

小偷

脆弱性

主人打瞌睡

风险

财宝被偷

业务影响

没饭吃



黑客

软件漏洞

被入侵

数据失密

风险处置策略

降低风险（Reduce Risk）

采取适当的控制措施来降低风险，包括技术手段和管理手段，如安装防火墙，杀毒软件，或是改善不规范的工作流程、制定业务连续性计划，等等。

避免风险（Avoid Risk）

通过消除可能导致风险发生的条件来避免风险的发生，如将公司内外网隔离以避免来自互联网的攻击，或是将机房安置在不可能造成水患的位置，等等。

转移风险（Transfer Risk）

将风险全部或者部分地转移到其他责任方，例如购买商业保险。

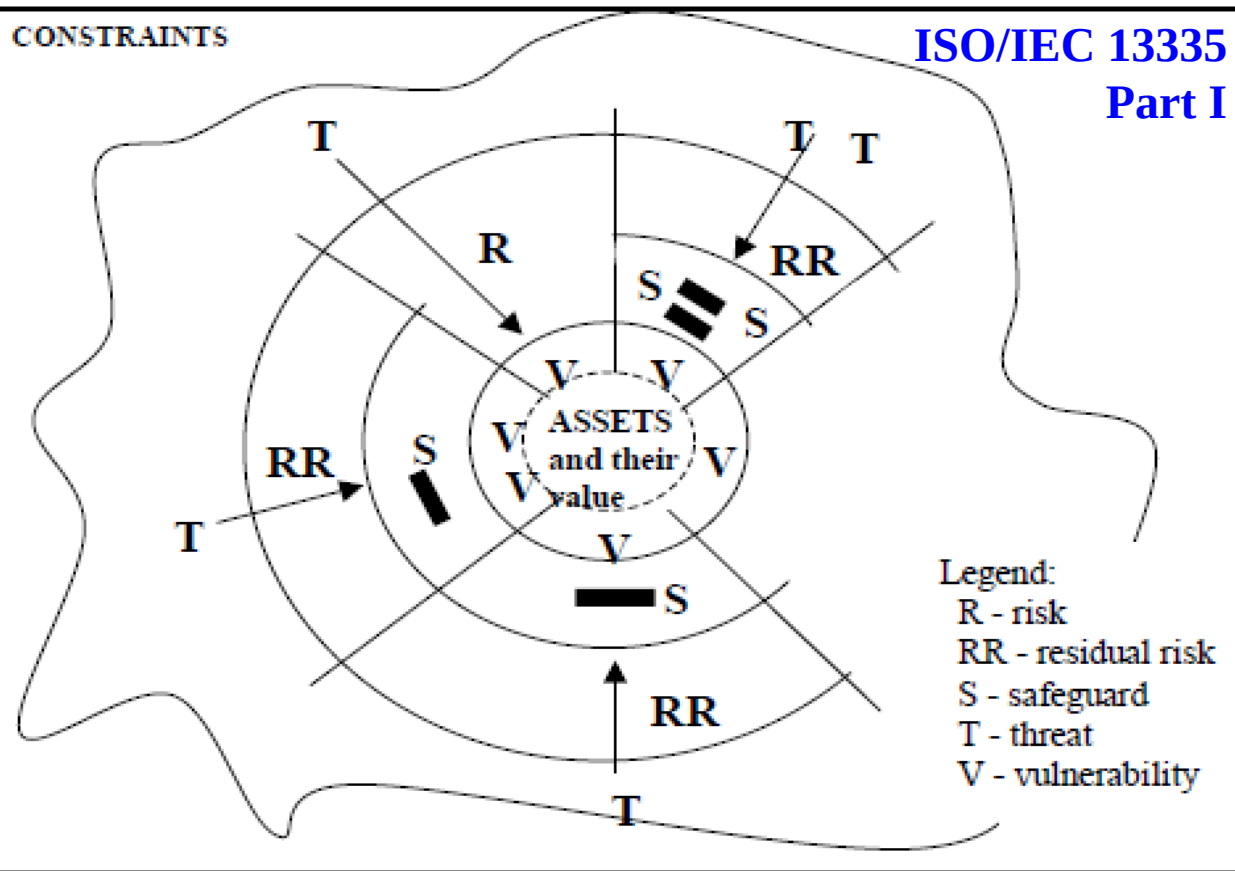
接受风险（Accept Risk）

在实施了其他风险应对措施之后，对于残留的风险，可以有意识地选择接受。

如何度量风险的大小？

安全风险概念模型

安全风险组成的四要素：信息系统资产（Asset）、信息系统脆弱性（Vulnerability）、信息安全威胁（Threat）、信息系统安全保护措施（Safeguard）。

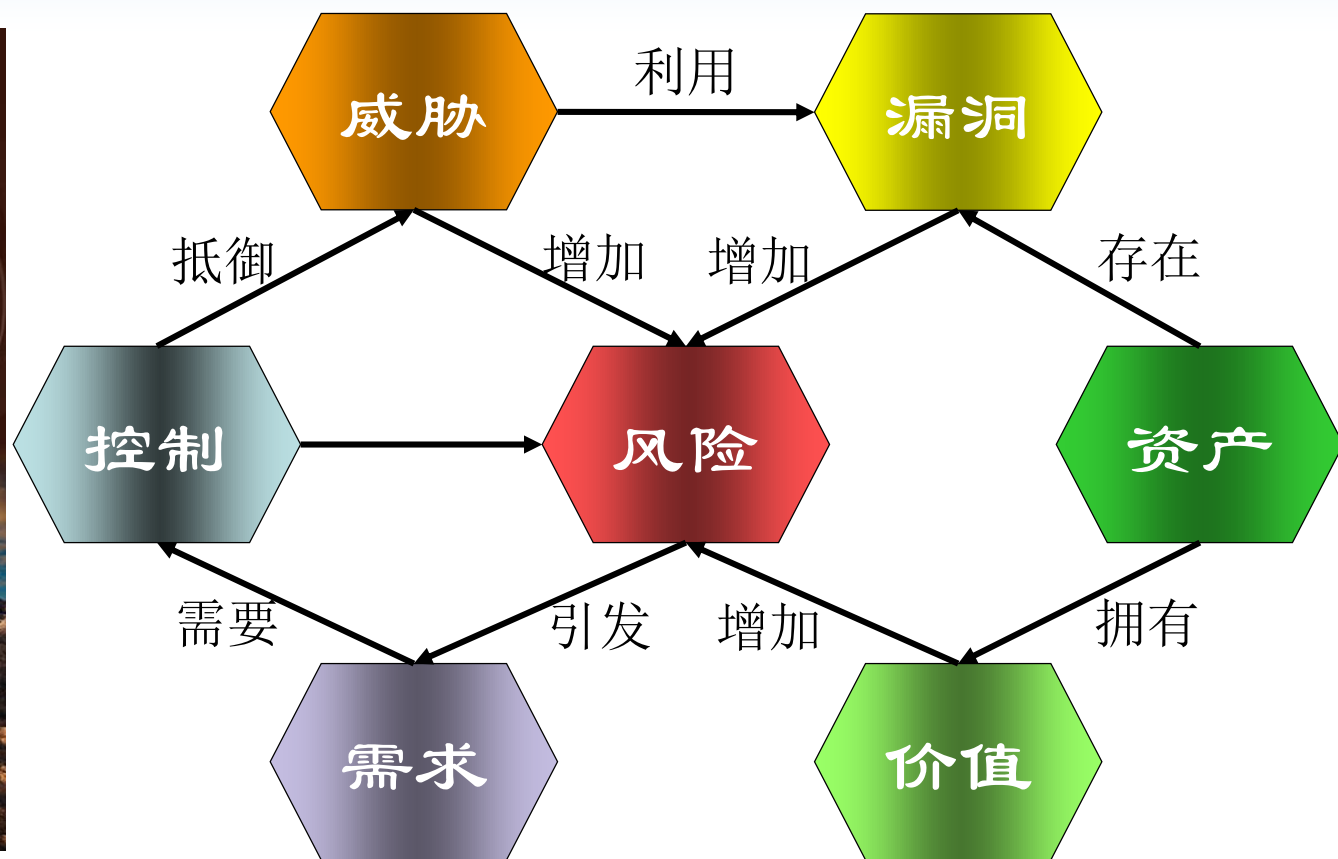


信息安全风险产生的内因、外因及其相互辩证关系

- 信息系统本身的脆弱性和安全保护措施的漏洞、薄弱点就是产生安全风险的内因
- 对资产的威胁欲望动机及其实施能力就是产生安全风险的外在因素

风险评估的基本思想

ISO13335



风险评估是参照国家有关标准对信息系统及由其处理、传输和存储信息的保密性、完整性和可用性安全属性进行分析和评价的过程。它要分析：

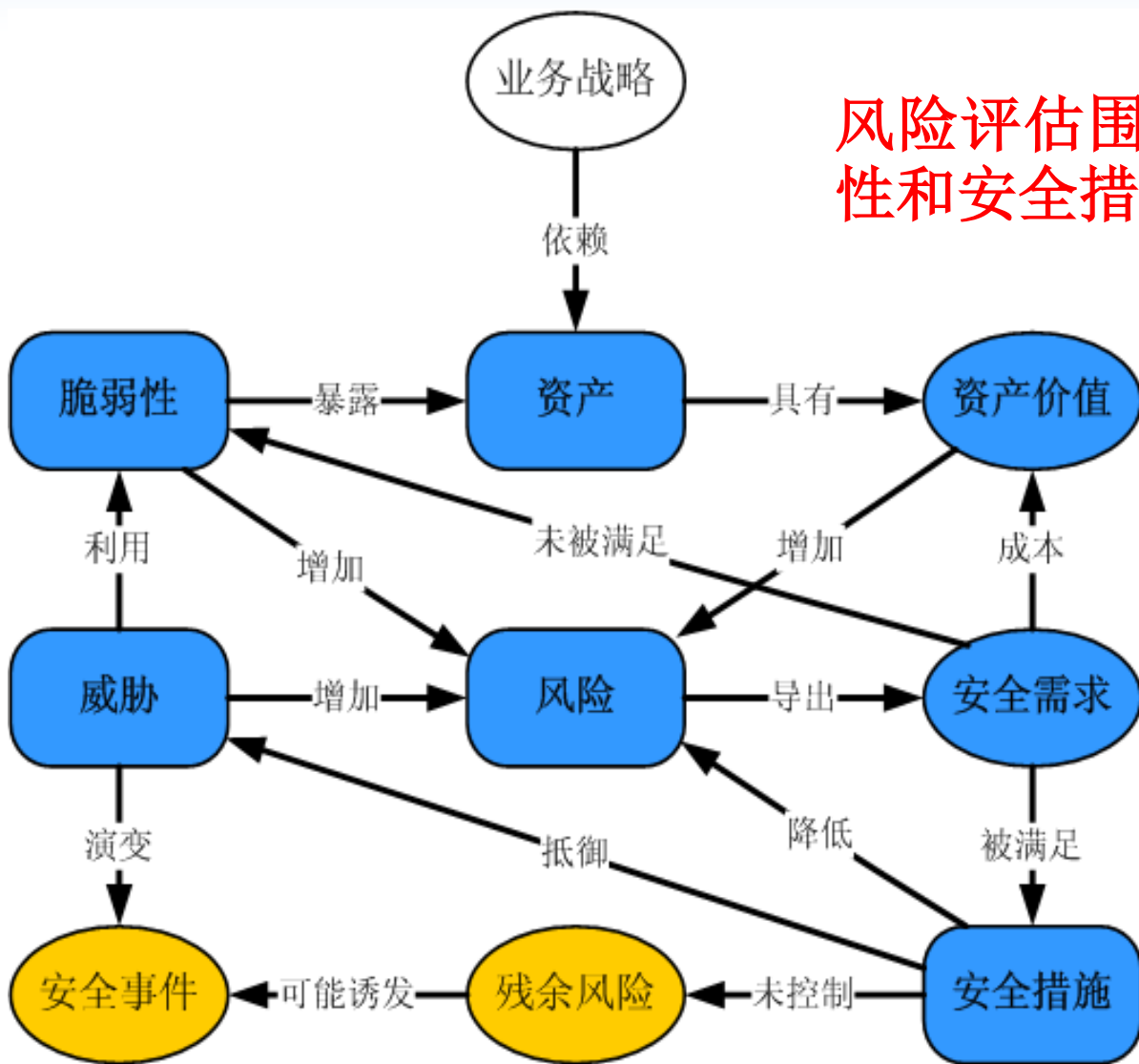
- (1) 资产面临的威胁及威胁利用脆弱性导致安全事件的**可能性**；
- (2) 根据资产价值来判断安全事件一旦发生对组织**造成的影响**。

风险评估的要素

风险评估围绕着资产、威胁、脆弱性和安全措施这些基本要素展开。

在对基本要素的评估过程中，需要充分考虑业务战略、资产价值、安全需求、安全事件、残余风险等与这些基本要素相关的各类属性。

方框部分的内容为风险评估的基本要素，椭圆部分的内容是与这些要素相关的属性



风险评估的要素

业务战略依赖
资产去实现

业务战略

依赖

风险评估实质上就是要度量风险
各要素之间的相互作用关系

脆弱性

暴露

资产

具有

资产价值

利用

威胁

增加

未被满足

增加

成本

增加

风险

导出

安全需求

演变

抵御

降低

被满足

安全事件

可能诱发

残余风险

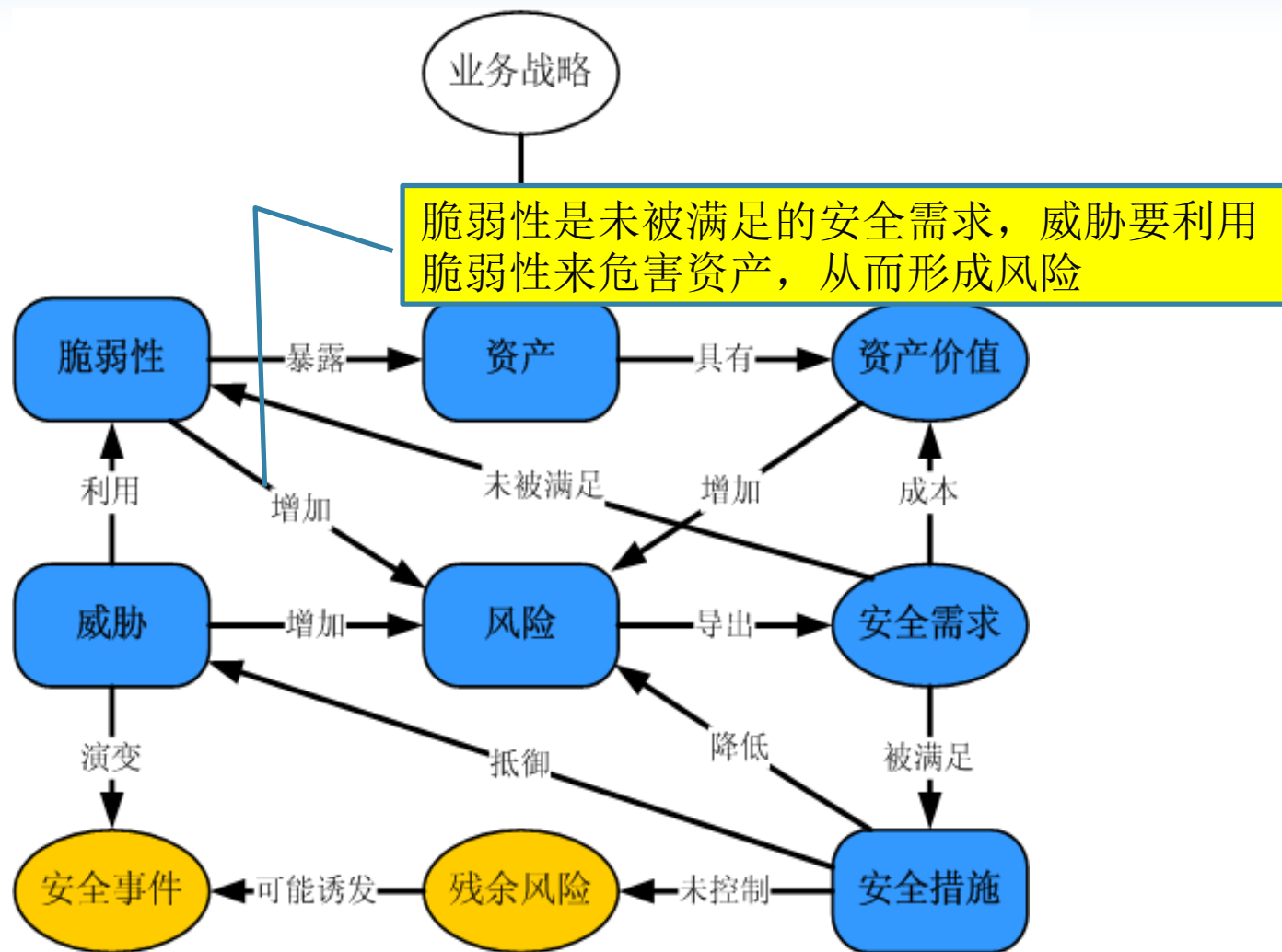
未控制

安全措施

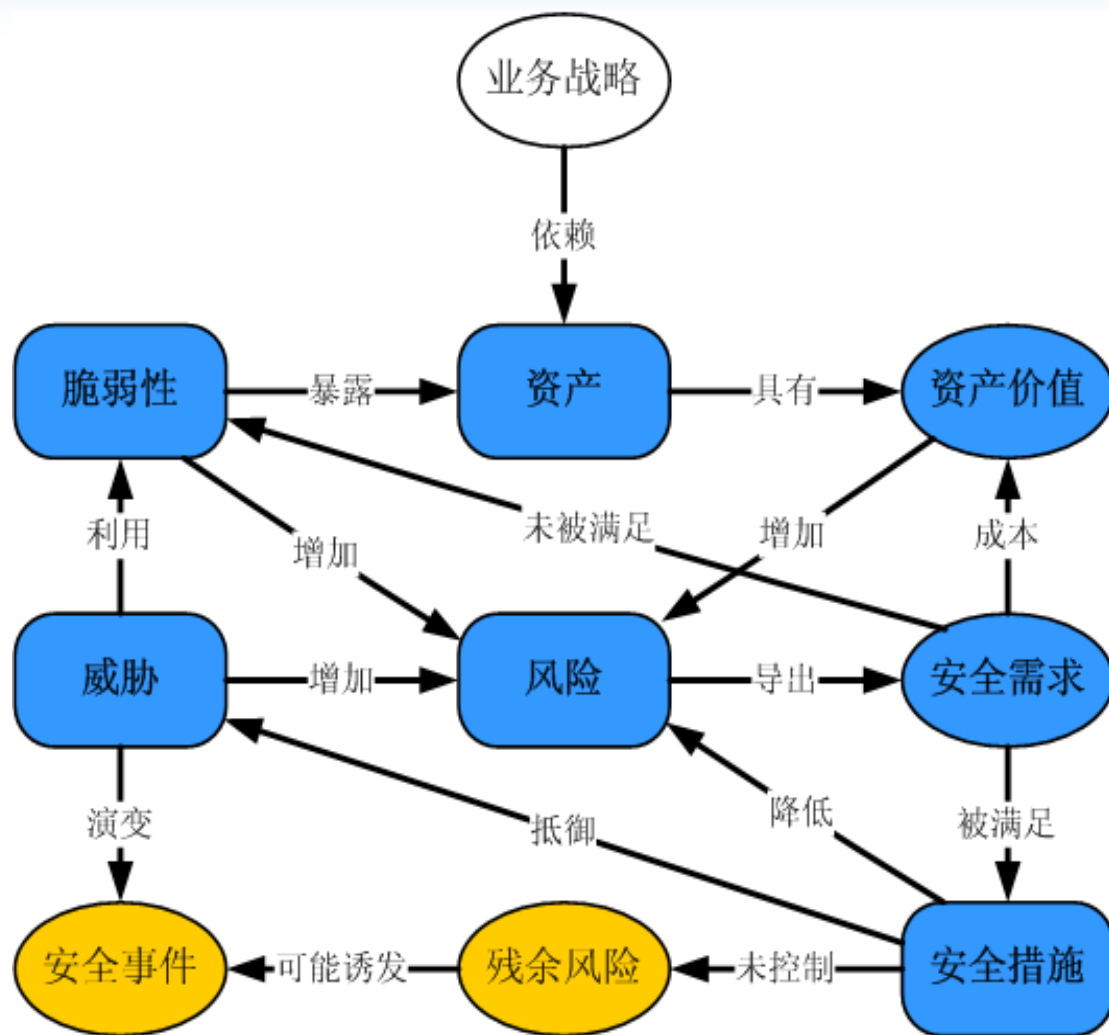
- 资产是有价值的，组织的业务战略对资产的依赖度越高，资产价值就越大；
- 资产价值越大则其面临的风险越大；
- 风险是由威胁引发的，资产面临的威胁越多则风险越大，并可能演变成安全事件；

风险评估的要素

脆弱点越多，威胁利用脆弱性导致安全事件的可能性越大

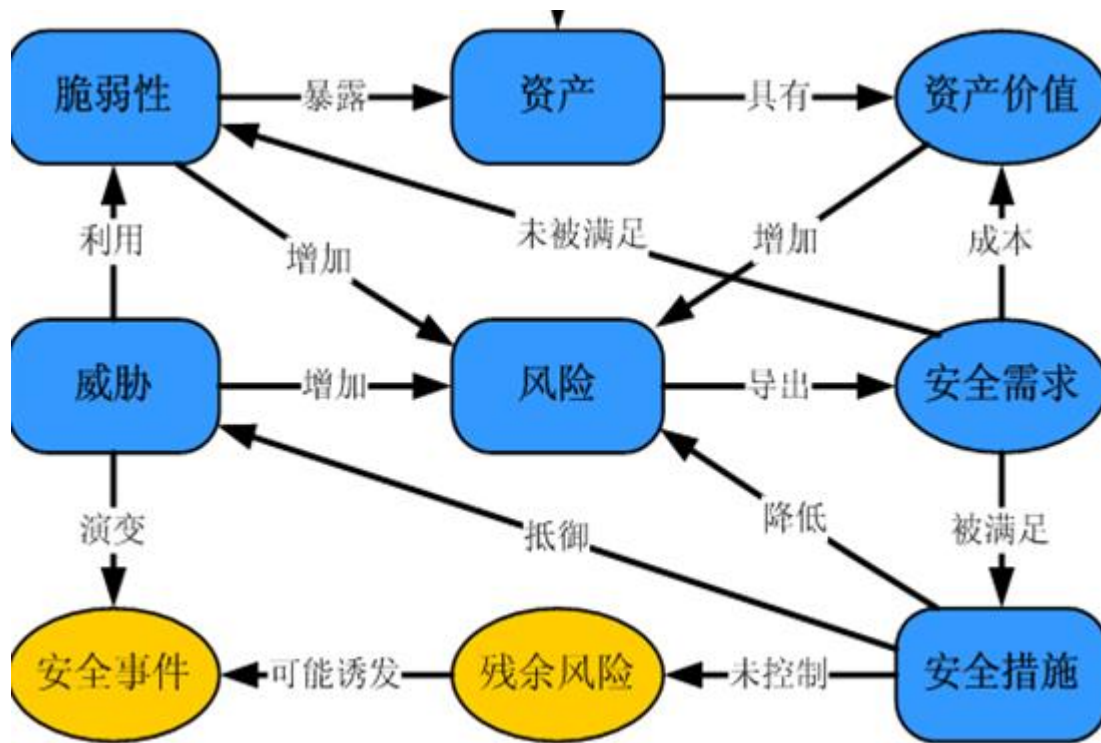


风险评估的要素



- 风险的存在及对风险的认识导出安全需求
- 安全需求可通过安全措施得以满足，需要结合资产价值考虑实施成本

风险评估的要素



残余风险应受到密切监视，它可能会在将来诱发新的安全事件

风险不可能也没有必要降为零，在实施了安全措施后还会有残留下来的风险。有些残余风险来自于安全措施可能不当或无效，在以后需要继续控制，而有些残余风险则是在综合考虑了安全成本与效益后未控制的风险，是可以被接受的

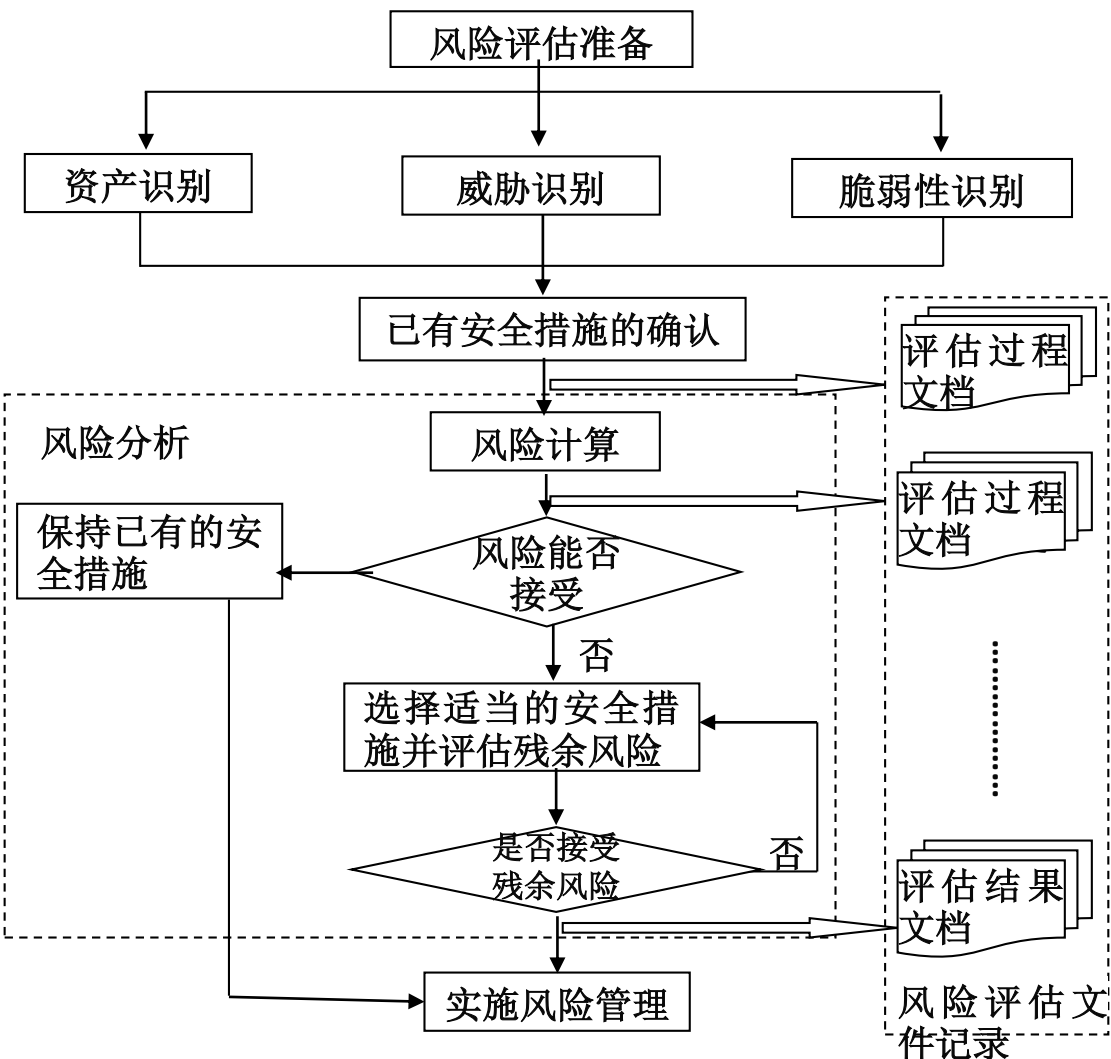
信息系统安全风险计算模型（GB/T20984-2007）

风险计算模型是对通过风险分析计算风险值过程的抽象，它主要包括资产评估、威胁评估、脆弱性评估。



资产、威胁、脆弱性等基本要素有各自的属性：资产的属性是资产价值，威胁的属性是威胁出现的频率，脆弱性的属性是资产弱点的严重程度。

安全风险评估的框架及流程（GB/T20984-2007）

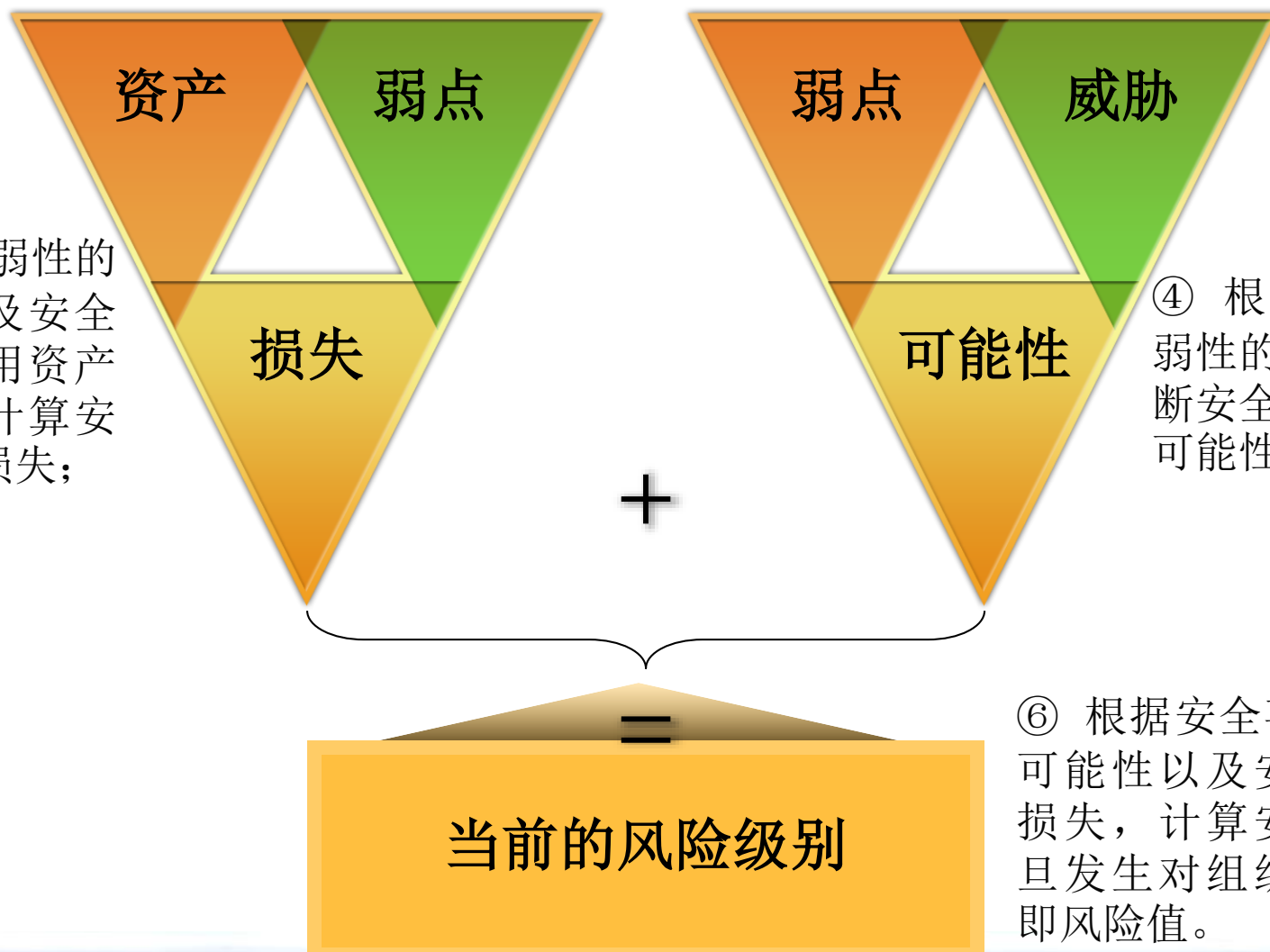


① 对资产进行识别，并对资产的重要性进行赋值；

② 对威胁进行识别，描述威胁的属性，并对威胁出现的频率赋值；

③ 对资产的脆弱性进行识别，并对具体资产的脆弱性的严重程度赋值；

风险分析方法示意图



⑤ 根据脆弱性的严重程度及安全事件所作用资产的重要性计算安全事件的损失；

④ 根据威胁和脆弱性的识别结果判断安全事件发生的可能性；

⑥ 根据安全事件发生的可能性以及安全事件的损失，计算安全事件一旦发生对组织的影响，即风险值。

资产分类方法

分类	示例
数据	保存在信息媒介上的各种数据资料，包括源代码、数据库数据、系统文档、运行管理规程、计划、报告、用户手册、各类纸质的文档等
软件	系统软件：操作系统、数据库管理系统、语句包、开发系统等 应用软件：办公软件、数据库软件、各类工具软件等 源程序：各种共享源代码、自行或合作开发的各种代码等
硬件	网络设备：路由器、网关、交换机等 计算机设备：大型机、小型机、服务器、工作站、台式计算机、便携计算机等 存储设备：磁带机、磁盘阵列、磁带、光盘、软盘、移动硬盘等 传输线路：光纤、双绞线等 保障设备：UPS、变电设备等、空调、保险柜、文件柜、门禁、消防设施等 安全保障：防火墙、入侵检测系统、身份鉴别等 其他：打印机、复印机、扫描仪、传真机等
服务	信息服务：对外依赖该系统开展的各类服务 网络服务：各种网络设备、设施提供的网络连接服务 办公服务：为提高效率而开发的管理信息系统，包括各种内部配置管理、文件流转管理等服务
人员	掌握重要信息和核心业务的人员，如主机维护主管、网络维护主管及应用项目经理等
其他	企业形象、客户关系等

资产评估——资产分类调查

项目名称	资产分类调查
简要描述	采集资产信息，进行资产分类；
达成目标	采集资产信息，进行资产分类； 进一步明确评估的范围和重点；
主要内容	采集相关系统资产信息，获取资产清单； 进行资产分类划分；
实现方式	● 调查 ■ 填表式调查 《资产调查表》，包含计算机设备、网络通讯设备、存储及保障设备、安全设备、业务系统、软件等。 ● 交流 ■ 审阅已有的针对资产的安全管理规章、制度； ■ 与高级主管、网络管理员（系统管理员）等进行交流。 ● 工具 ■ 扫描器
工作结果	资产清单（分类）
参加人员	依据现场状况，公司全体评估人员在客户相关技术和管理人员的配合下进行资产分类调查

资产保密性赋值

赋值	标识	定义
5	很高	包含组织最重要的秘密，关系未来发展的前途命运，对组织根本利益有着决定性的影响，如果泄露会造成对组织的灾难性损害（如电子政务内网中传递的国家秘密等）
4	高	包含组织的重要秘密，其泄露会使得组织的安全和利益遭受严重损害
3	中等	组织的一般秘密，其泄露会使得组织的安全和利益受到损害
2	低	仅能在组织内部或组织某一部门内部公开的信息，向外扩散有可能对组织的利益造成轻微损害
1	很低	可对社会公开的信息，公用的信息处理设备和系统资源等（如门户网站）
备注：具体的赋值情况由风险评估人员和被评估单位人员共同确定		

资产完整性赋值

赋值	标识	定义
5	很高	完整性价值非常关键，未经授权的修改或破坏会对组织造成重大的或无法接受的影响，对业务冲击重大，并可能造成严重的业务中断，难以弥补
4	高	完整性价值较高，未经授权的修改或破坏会对组织造成重大影响，对业务冲击严重，较难弥补
3	中等	完整性价值中等，未经授权的修改或破坏会对组织造成影响，对业务冲击明显，但可以弥补
2	低	完整性价值较低，未经授权的修改或破坏会对组织造成轻微的影响，对业务冲击轻微，容易弥补
1	很低	完整性价值非常低，未经授权的修改或破坏会对组织造成的影响可以忽略，对业务冲击可以忽略
备注：具体的赋值情况由风险评估人员和被评估单位人员共同确定		

资产可用性赋值

赋值	标识	定义
5	很高	可用性价值非常高，合法使用者对信息及其信息的可用度达到年度 99.9% 以上，或系统不运行中断
4	高	可用性价值非常高，合法使用者对信息及其信息的可用度达到年度 90% 以上，或系统允许中断时间小于 10 分钟
3	中等	可用性价值中等，合法使用者对信息及其信息的可用度在正常工作时间达到 70% 以上，或系统允许中断时间小于 30 分钟
2	低	可用性价值较低，合法使用者对信息及其信息的可用度在正常工作时间达到 25% 以上，或系统允许中断时间小于 60 分钟
1	很低	可用性价值可以忽略，合法使用者对信息及其信息的可用度在正常工作时间低于 25%
备注：具体的赋值情况由风险评估人员和被评估单位人员共同确定		

资产等级计算公式

$$AV=F(AC, AI, AA)$$

Asset Value 资产价值

Asset Confidentiality 资产保密性赋值

Asset Integrity 资产完整性赋值

Asset Availability 资产可用性赋值

例1: $AV=MAX(AC, AI, AA)$

例2: $AV=AC+AI+AA$

例3: $AV=AC \times AI \times AA$

资产价值赋值

等级	标识	描述
5	很高	非常重要，其安全属性破坏后可能对组织造成非常严重的损失
4	高	重要，其安全属性破坏后可能对组织造成比较严重的损失
3	中等	比较重要，其安全属性破坏后可能对组织造成中等程度的损失
2	低	不太重要，其安全属性破坏后可能对组织造成较低的损失
1	很低	不重要，其安全属性破坏后对组织造成导很小的损失，甚至忽略不计
备注：具体赋值情况由风险评估人员和被评估单位人员共同确定		

威胁来源列表

来源		描述
环境因素		断电、静电、灰尘、潮湿、温度、鼠蚁虫害、电磁干扰、洪灾、火灾、地震、意外 事故等环境危害或自然灾害，以及软件、硬件、数据、通信线路等方面的故障
人为因素	恶意人员	不满的或有预谋的内部人员对信息系统进行恶意破坏； 采用自主或内外勾结的方式盗窃机密信息或进行篡改，获取利益 外部人员利用信息系统的脆弱性,对网络或系统的机密性、完整性和可用性进行破坏， 以获取利益或炫耀能力
	非恶意人员	内部人员由于缺乏责任心，或者由于不关心和不专注，或者没有遵循规章制度和操作流程而导致故障或信息损坏； 内部人员由于缺乏培训、专业技能不足、不具备岗 位技能要求而导致信息系统故障或被攻击。

威胁赋值

等级	标识	定义
5	很高	出现的频率很高（或 ≥ 1 次/周）；或在大多数情况下几乎不可避免；或可以证实经常发生过
4	高	出现的频率较高（或 ≥ 1 次/月）；或在大多数情况下很有可能会发生；或可以证实多次发生过
3	中等	出现的频率中等（或 > 1 次/半年）；或在某种情况下可能会发生；或被证实曾经发生过
2	低	出现的频率较小；或一般不太可能发生；或没有被证实发生过
1	很低	威胁几乎不可能发生；仅可能在非常罕见和例外的情况下发生

脆弱性识别内容表

类型	识别对象	识别内容
技术脆弱性	物理环境	从机房场地、机房防火、机房供配电、机房防静电、机房接地与防雷、电磁防护、通信线路的保护、机房区域防护、机房设备管理等方面进行识别
	网络结构	从网络结构设计、边界保护、外部访问控制策略、内部访问控制策略、网络设备安全配置等方面进行识别
	系统软件	从补丁安装、物理保护、用户账号、口令策略、资源共享、事件审计、访问控制、新系统配置、注册表加固、网络安全、系统管理等方面进行识别
	应用中间件	从协议安全、交易完整性、数据完整性等方面进行识别。
	应用系统	从审计机制、审计存储、访问控制策略、数据完整性、通信、鉴别机制、

脆弱性赋值

等级	标识	定义
5	很高	如果被威胁利用，将对资产造成完全损害
4	高	如果被威胁利用，将对资产造成重大损害
3	中等	如果被威胁利用，将对资产造成一般损害
2	低	如果被威胁利用，将对资产造成较小损害
1	很低	如果被威胁利用，将对资产造成的损害可以忽略

风险计算方法

$$\text{风险值} = R(A, T, V) = R(L(T, V), F(Ia, Va))$$

符号	含义
R	安全风险计算函数
A	资产
T	威胁
V	脆弱性
Ia	安全事件所作用的资产价值
Va	脆弱性严重程度
L	威胁利用资产的脆弱性导致安全事件发生的可能性
F	安全事件发生后产生的损失

一般风险计算方法：矩阵法和相乘法

风险等级表

等级	标识	描述
5	很高	一旦发生将产生非常严重的经济或社会影响，如组织信誉严重破坏、严重影响组织的正常经营，经济损失重大、社会影响恶劣
4	高	一旦发生将产生较大的经济或社会影响，在一定范围内给组织的经营和组织信誉造成损害
3	中等	一旦发生会造成一定的经济、社会或生产经营影响，但影响面和影响程度不大
2	低	一旦发生造成的影响程度较低，一般仅限于组织内部，通过一定手段很快能解决
1	很低	一旦发生造成的影响几乎不存在，通过简单的措施就能弥补

矩阵法风险计算

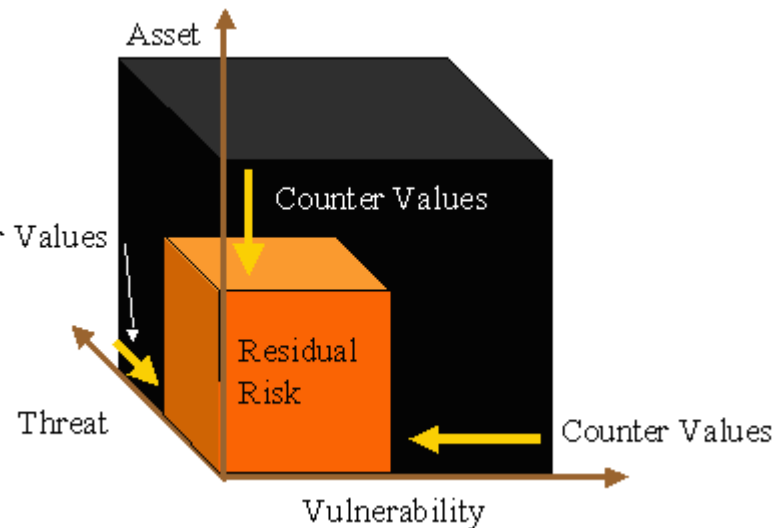
	风险可能性																									
	威胁值	1					2					3					4					5				
	弱点值	1	2	3	4	5	1	2	3	4	5	1	2	3	4	5	1	2	3	4	5	1	2	3	4	5
风险影响 资产价值	1	1	2	3	4	5	2	4	6	8	10	3	6	9	12	15	4	8	12	16	20	5	10	15	20	25
	2	2	4	6	8	10	4	8	12	16	20	6	12	18	24	30	8	16	24	32	40	10	20	30	40	50
	3	3	6	9	12	15	6	12	18	24	30	9	18	27	36	45	12	24	36	48	60	15	30	45	60	75
	4	4	8	12	16	20	8	16	24	32	40	12	24	36	48	60	16	32	48	64	80	20	40	60	80	100
	5	5	10	15	20	25	10	20	30	40	50	15	30	45	60	75	20	40	60	80	100	25	50	75	100	125

风险按照五级划分的，如下图所示：

风险等级					
风险值	1~25	26~50	51~75	76~100	101~125
风险等级	1	2	3	4	5

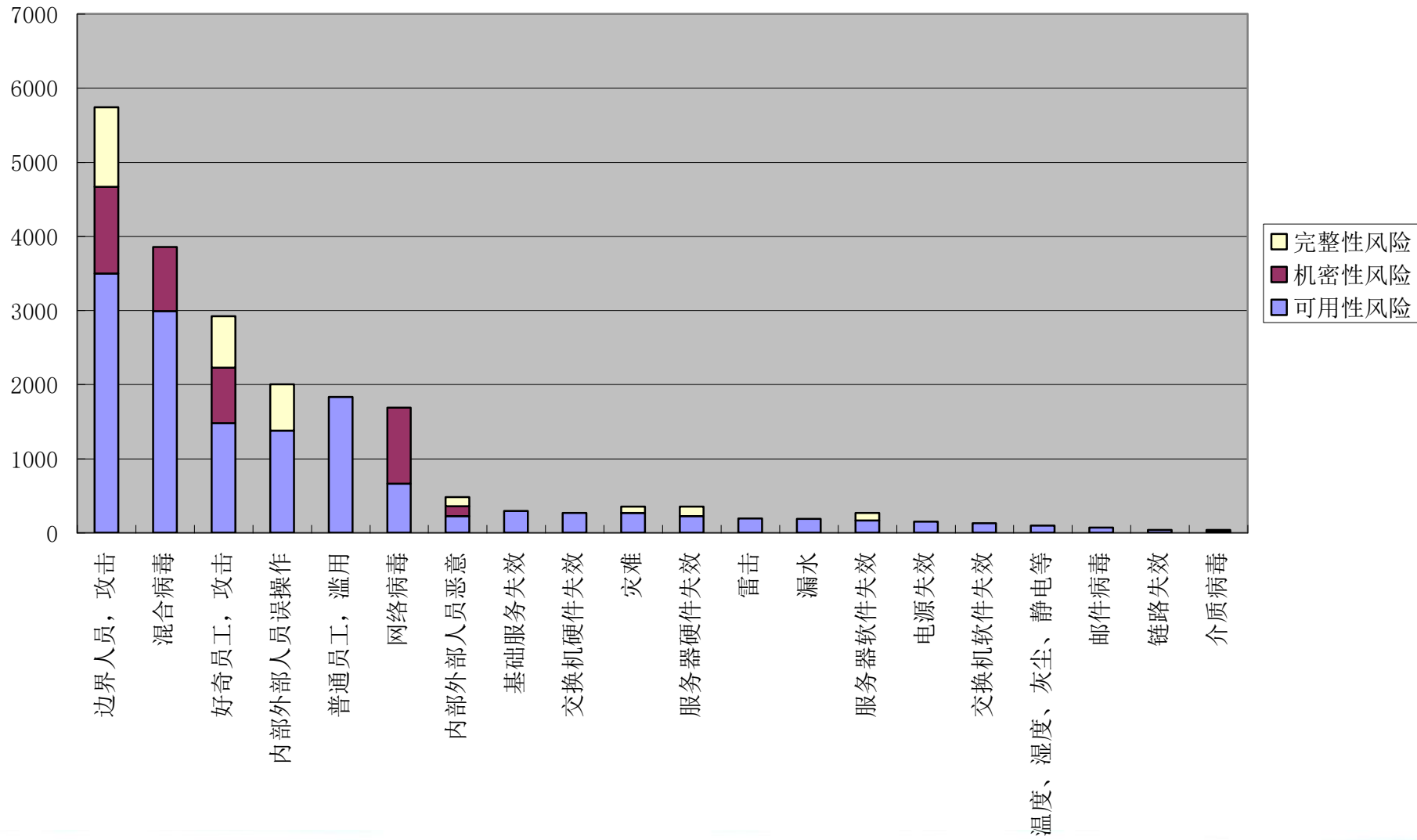
残留风险评价

- 绝对安全（即零风险）是不可能的
- 实施安全控制后会有残留风险或残存风险（Residual Risk）
- 为了确保信息安全，应该确保残留风险在可接受的范围内：
 - 残留风险 R_r = 原有的风险 R_0 - 控制 ΔR
 - 残留风险 $R_r \leq$ 可接受的风险 R_t
 - 对残留风险进行确认和评价的过程其实就是风险接受的过程。决策者可以根据风险评估的结果来确定一个阈值，以该阈值作为是否接受残留风险的标准。



残留风险实际上是安全和成本的权衡

风险评价示例



风险评估的成果文件

- ✚ 《资产评估报告》
- ✚ 《漏洞评估报告》
- ✚ 《威胁评估报告》
- ✚ 《风险评估报告》
- ✚ 《安全策略建议》
- ✚ 《安全解决方案》
- ✚ 《应急响应流程》
- ✚ 《操作系统加固手册》
- ✚ 《数据库加固手册》

风险评估 vs. 风险管理

风险



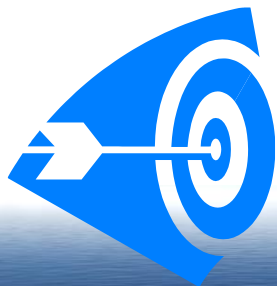
风险（**Risk**）是指各种威胁导致安全事件发生的可能性及其对组织所造成的负面影响。

风险评估

风险评估（**Risk Assessment**）就是对各方面风险进行辨识和分析的过程，它包括风险分析和 risk 评价，是确认安全风险及其大小的过程。

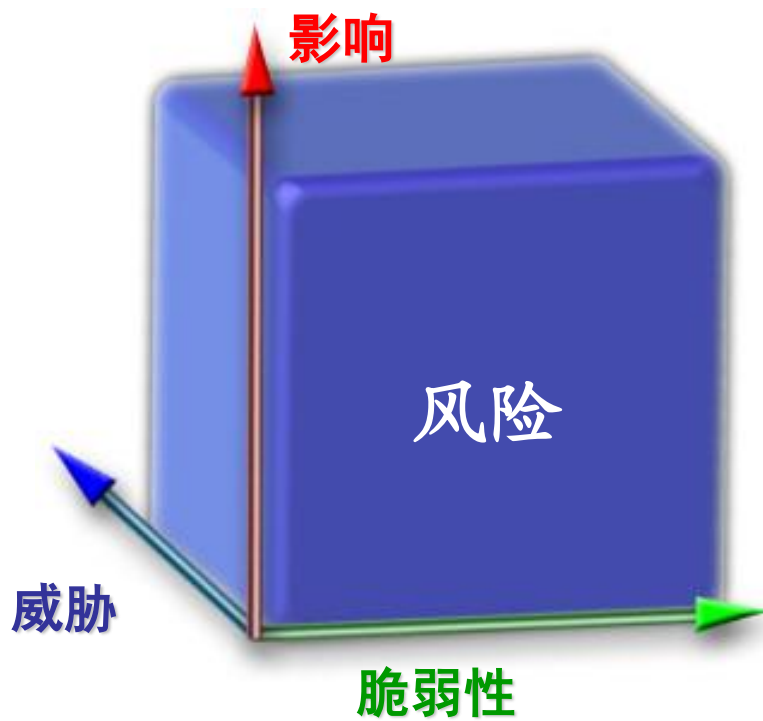


风险管理

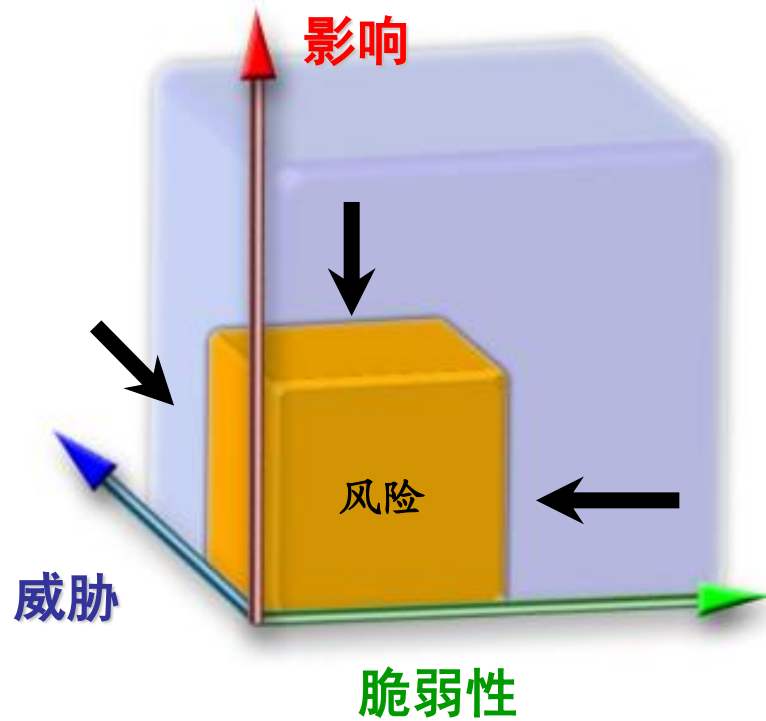


风险管理（**Risk Management**）就是以可接受的代价，识别、控制、减少或消除可能影响信息系统的安全风险的过程。

风险管理的目标



原有风险



采取措施后的剩余风险

风险管理标准



ICS 35.040
L 80



中华人民共和国国家标准

GB/T 31722—2015/ISO/IEC 27005:2008

信息技术 安全技术
信息安全风险管理

Information technology—Security techniques—
Information security risk management

(ISO/IEC 27005:2008, IDT)

2015-06-02 发布

2016-02-01 实施

中华人民共和国国家质量监督检验检疫总局
中国国家标准化管理委员会 发布

风险评估应贯穿于信息系统生命周期的各阶段

信息系统生命周期各阶段中涉及的风险评估的原则和方法是一致的，但由于各阶段实施的内容、对象、安全需求不同，使得风险评估的对象、目的、要求等各方面也有所不同。

- 在规划设计阶段，通过风险评估以确定系统的安全目标；
- 在建设验收阶段，通过风险评估以确定系统的安全目标达成与否；
- 在运行维护阶段，要不断地实施风险评估以识别系统面临的不断变化的风险和脆弱性，从而确定安全措施的有效性，确保安全目标得以实现。

因此，每个阶段风险评估的具体实施应根据该阶段的特点有所侧重地进行。

一种新的风险评估——数据风险评估

2016年11月，《中华人民共和国网络安全法》正式发布，国家从法律层面上对网络运营者提出了要求，其中第二十一条的内容对网络数据的保护提出了要求；

2019年5月，《数据安全管理办法（征求意见稿）》中，第四条、第三十五条，对数据安全出境的风险和针对个人信息的数据安全事件提出了保护要求；2021年6月，《中华人民共和国数据安全法》正式发布，其中对国家和重要数据的处理者，都提出了针对数据安全风险评估的需求。

从以上这些法律法规要求来看，**企业网络数据保护、出境数据安全、个人敏感信息数据安全都需要定期开展风险评估工作**，并在风险评估报告中明确企业处理数据的种类和量级，活动情况和可能面临的风险，以及相对应的整改措施。

当历史遇上管理学 | 从荆轲刺秦看被秦王忽略的风险管理



呼兮不寒風
氣入堪壯蕭
兮蛟還士蕭
成宮探一兮
白仰席去易
虹天所于水

怎么做风险评估？

做好计划，抓好落实，实事求是

风险评估项目实施过程

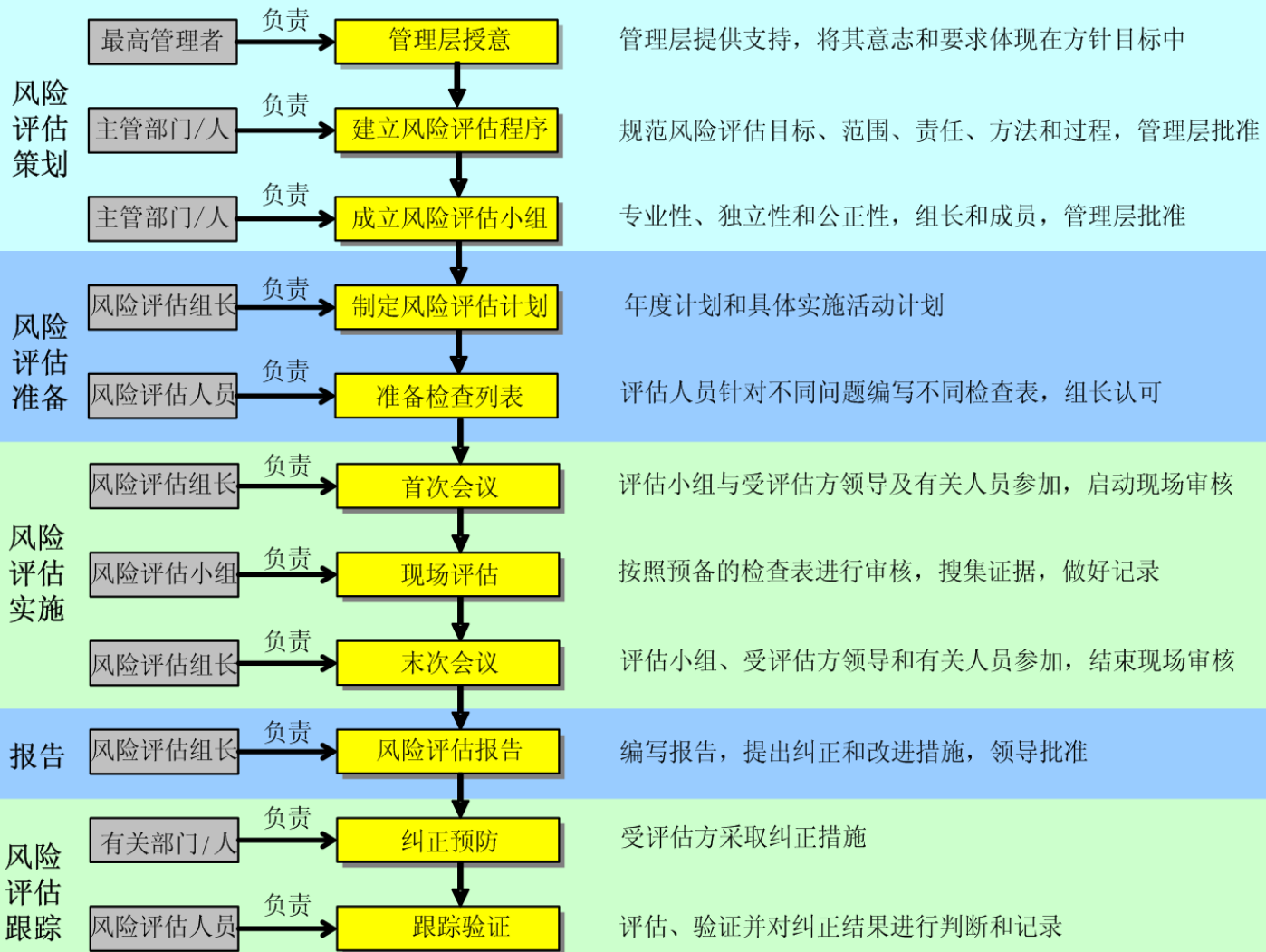
策划

准备

实施

报告

跟踪



评估工作各角色的责任

评估组长	评估员	XX公司安全管理员
- 负责管理问卷访谈和运维问卷访谈； - 组织评估活动，控制协调进度，保证按计划完成评估任务； - 组织召开评估会议； - 代表评估小组与受评估方管理层接触； - 组织撰写风险评估报告、现状报告和安全改进建议 - 提交评估报告	- 负责风险评估技术部分的内容包括：网络、主机系统、应用和数据库评估 - 熟悉必要的文件和程序； - 准备风险评估技术评估工具； - 撰写每单位的评估报告； - 配合支持评估组长的工作，有效完成评估任务； - 收存和保护与评估有关的文件	- 负责配合评估顾问提供风险评估相关的工作环境、评估实现条件； - 备份系统数据； - 配合评估顾问完成资产分类、赋值、弱点威胁发现和赋值、风险处理意见等工作； - 掌握风险评估方法； - 收存和保护与评估有关的文件 - 完成扫描后，检查风险评估后系统的安全性和稳定性

制定评估计划

评估计划分年度计划和具体的实施计划

评估计划

通常是评估策划阶段就需要完成，是整个评估活动的总纲。

通常应该包含以下内容：

目的：申明组织实施内部评估的目标。

时间安排：评估时间避免与重要业务活动发生冲突。

评估类型：是否采用集中方式？

其他考虑因素：范围、评估组织、评估要求、特殊情况等。

评估实施计划

遵照年度评估计划而对每次的评估活动所作的实施安排。

内容通常包括：

目的、范围、准则、评估组成员及分工、评估时间和地点、首末次会议及报告时间

评估计划应以文件形式颁发，评估实施计划应该有评估组长签名并得到主管领导的批准。

风险评估计划示例

评估目的	评价信息安全管理体系运行的符合性和有效性			
评估范围	××××××××××××××××××			
评估准则	《XX公司信息安全管理办法》《ISO27001信息安全管理体系》。			
评估小组	评估组长	×××		
	评估组员	××× ××× ××× ××× ×××		
评估活动		时间	负责人	备注
	填写信息资产采集表	X月上旬	×××	
	实施风险评估过程	X月中旬	×××	
	不符合项及高危风险纠正	X月末	各相关部门负责人	
	跟踪验证	X月上旬	评估小组	
	召开风险评估整改会议	X月下旬	信息部领导	
编制	编写者	×××		
	时间	×××年×月×日		
评估	评估者	×××（信息按照专责签字）		
	时间	×××年×月×日		
批准	批准者	×××（信息部门领导签字）		
	时间	×××年×月×日		

风险评估计划示例

评估目的	对ISMS进行内部评估，为体系纠正提供依据，为管理评审提供输入					
评估范围	××××××××××××××					
评估准则	《XX公司信息安全管理办法》《ISO27001信息安全管理体​​系》。					
评估方式	集中式评估					
评估时间	X年X月X—X月X日					
评估组织	评估组长	×××				
	评估组员	第一小组	××× ××× ×××			
		第二小组	××× ××× ×××			
评估安排	日期	时间	评估区域		评估内容	
			第一小组	第二小组	第一小组	第二小组
	X	9:00-9:30	会议室		首次会议	
		9:30-12:00				
		14:00-17:00				
		17:00-18:00				
	X	9:00-11:00				
		11:00-12:00	会议室		评估小组会议	
		14:00-15:00	会议室		末次会议	
	编制	编写者	×××		时间 ×××年×月×日	
评估	评估者	×××（信息安全管理​​员签字）		时间 ×××年×月×日		
批准	批准者	×××（信息部管理者签字）		时间 ×××年×月×日		

检查列表的四要素

去哪里？



找谁？



查什么？



如何查？



评估员检查工具——检查列表

评估员根据自己的需要，事先编制针对某方面问题的检查列表，然后逐项检查符合性。检查列表（Checklist）是评估员进行评估时必备的自用工具，是评估前需准备的一个重要工作文件。

在实施评估之前，评估员将根据分工情况来准备各自在现场评估所需的检查列表，检查列表的内容，取决于评估主题和被评估部门的职能、范围、评估方法及要求。

- ◆ 检查列表在信息安全管理内部评估中起着以下重要作用：
 - 明确与评估目标有关的抽样问题；
 - 使评估程序规范化，减少评估工作的随意性和盲目性；
 - 保证评估目标始终明确，突出重点，避免在评估过程中因迷失方向而浪费时间；
 - 更好地控制评估进度；

检查列表、评估计划和评估报告都作为评估记录而存档。

确认检查列表的方式

在确认检查列表应答时，评估员可以采取调查问卷、文件审查、现场观察和人员访谈等方式。

◆ 文件评估：评估员在现场评估之前，应该对受评估方与信息安全管理活动相关的所有文件进行审查，包括安全方针和目标、程序文件、作业指导书和记录文件。

◆ 现场观察：评估员到现场参观，可以观察并获取关于现场物理环境、信息系统的安全操作和各类安全管理活动的第一手资料。

◆ 人员访谈：与受评估方人员进行面谈，评估员可以了解其职责范围、工作陈述、基本安全意识、对安全管理获知的程度等信息。评估员进行人员访谈时要做好记录和总结，必要时要和访谈对象进行确认。

◆ 技术评估：评估员可以采用各种技术手段，对技术性控制的效力及符合性进行评估。这些技术性措施包括：自动化的扫描工具、网络拓扑结构分析、本地主机审查、渗透测试等。

检查列表编写注意事项

- ◆ 检查列表编写的依据，是评估准则，也就是信息安全管理标准、组织信息安全方针手册等文件的要求
- ◆ 针对受评估部门的特点，重点选择某些应该格外关注的信息安全问题
- ◆ 信息的收集和验证的方法应该多种多样，包括面谈、观察、文件和记录的收集和汇总分析、从其他信息源（客户反馈、外部报告等）收集信息等
- ◆ 检查列表应该具有可操作性
- ◆ 检查列表内容应该能够覆盖体系所涉及的全部范围和安全要求
- ◆ 如果采用了技术性评估，可在检查列表中列出具体方法和工具
- ◆ 检查列表的形式和详略程度可采取灵活方式
- ◆ 检查列表要经过信息安全主管人员审查无误后才能使用

常用技术工具清单

◆ 技术漏洞扫描工具

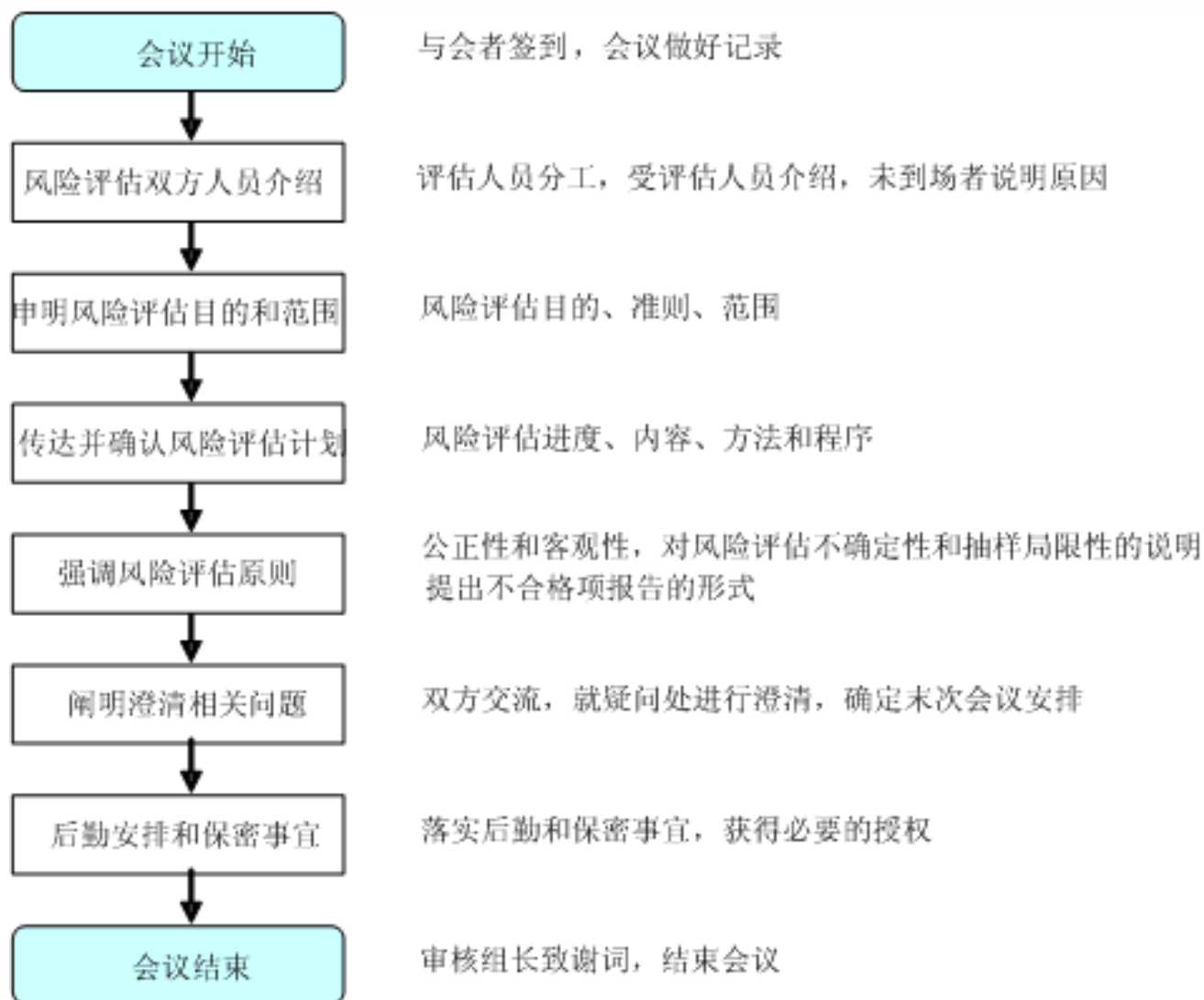
- 针对操作系统、典型应用软件漏洞（Nessus、绿盟极光、启明天镜）
- 针对网络端口（Nmap）
- 针对数据库漏洞（安信通、安恒）
- 针对Web漏洞（IBM Appscan、HP WebInspect WVS）
- 针对网络数据流（WireShark、Ethereal）

召开首次会议

- ◆ 在完成全部评估准备工作之后，评估小组就可以按照预先的计划实施现场评估了，现场评估开始于首次会议，评估小组全体成员和受评估方领导及相关人员共同参加。
- ◆ 首次会议由评估组长主持，评估小组要向组织的相关人员介绍评估计划、具体内容、评估方法，并协调、澄清有关问题。
- ◆ 召开首次会议时，与会者应该做好正式记录。



首次会议议程及内容



风险评估原则

- ◆ 在风险评估前，需要对技术评估的风险进行重审。
- ◆ 被评估方应在接受技术评估前对业务系统备份。
- ◆ 在技术扫描过程中，需要系统管理员全程陪同。
- ◆ 参考最近一年的风险评估记录。
- ◆ 在遇到异常情况时，及时通知管理员，并且停止评估。
- ◆ 技术评估安排在对系统影响较小的时间进行

实施现场评估

- ◆ 首次会议之后，即可进入现场评估。现场评估按计划进行，评估内容参照事先准备好的检查列表。
- ◆ 评估期间，评估员应该做好笔记和记录，这些记录是评估员提出报告的真凭实据。记录的格式可以是“笔记式”，也可以是“记录表式”，一般来说，内审活动都应该有统一的“现场评估记录表”，便于规范化管理。
- ◆ 评估进行到适当阶段，评估组长应该主持召开评估小组会议，借此了解各个评估员的工作进展，提出下一步工作要求，协调有关活动，并对已获得的评估证据和评估发现展开分析和讨论。

对不符合项进行描述

◆ 无论是严重不符合项还是轻微不符合项，评估员都应该将其记录到不符合项报告中。不符合项报告是对现场评估得到的评估发现进行评审并经过受评估方确认的对不符合项的陈述，是最终的评估报告的一部分，是评估小组提交给委托方或受评估方的正式文件。

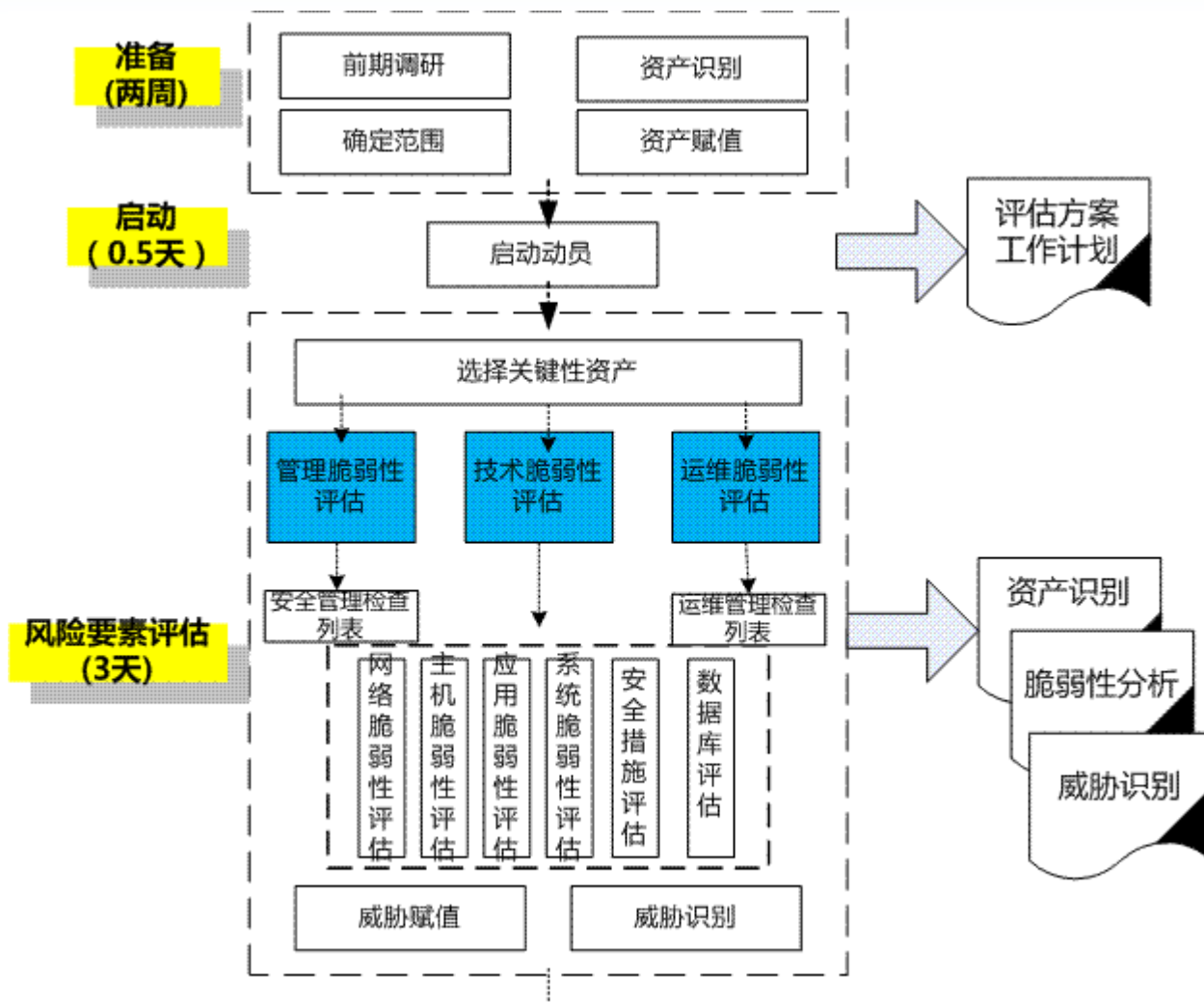
◆ 不符合项描述应该明确以下内容：

- 在哪里发现的？描述相关区域、文件、记录、设备
- 发现了什么？客观描述发现的事实
- 有谁在场？或者和谁有关？描述相关人员、职位
- 为什么不合格？描述不符合原因，所违背的标准或文件条款

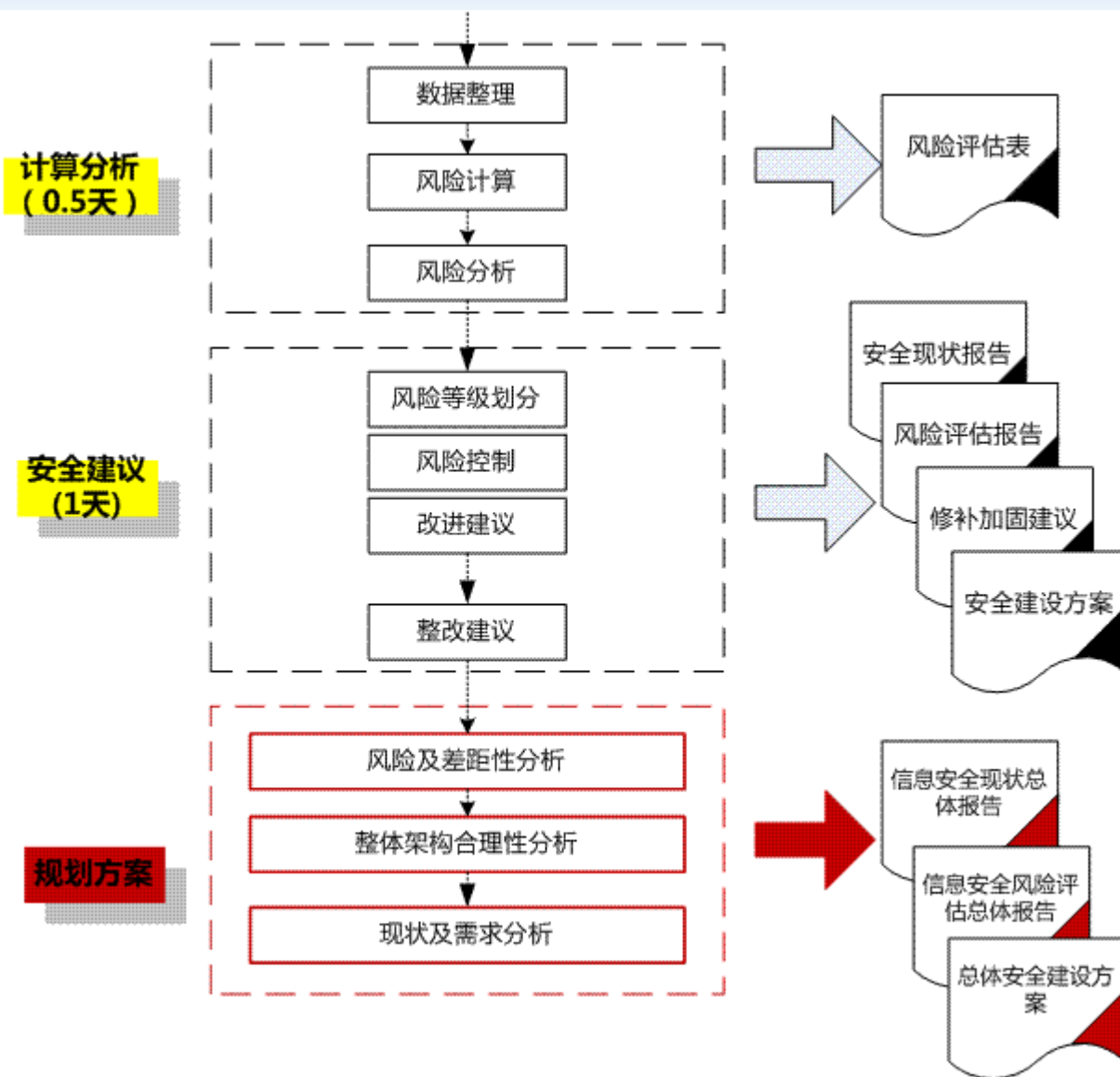
◆ 在对不符合项进行描述时，应该注意：

- 不符合项描述务必清楚明白，便于追溯
- 描述语句务必正规，采用标准术语

现场工作时间安排（一）



现场工作时间安排（二）



召开评估小组会议

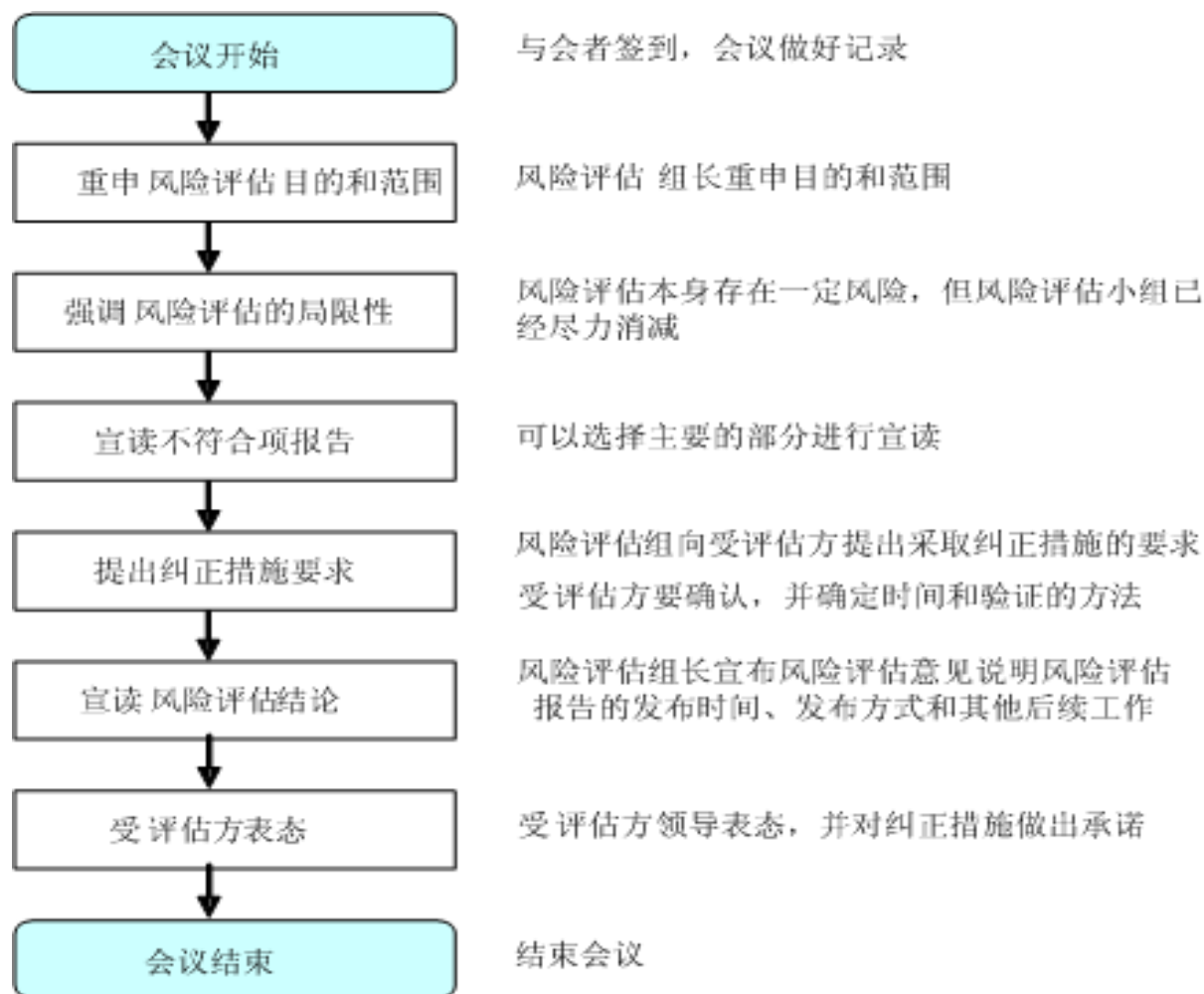
- ◆ 现场评估结束后，末次会议召开之前，评估小组应该召开内部碰头会。或者是在整个评估过程中，定期（每天结束时）召开评估小组碰头会
- ◆ 同一评估小组的成员参加
- ◆ 会议期间讨论当前的评估结果
- ◆ 沟通评估信息、线索
- ◆ 协调评估方向，控制评估实施按计划进行
- ◆ 评估组长作评估总结准备。在末次会议之前的评估组会议中，评估组长要对评估的观察结果作一次汇总分析：
 - 从发现的风险进行分析（发生的部门、要素、性质、类型）
 - 从技术漏洞的趋势分析（不同业务系统的比较）
 - 从体系运行状况对影响情况进行分析
 - 总结各项安全措施落实的优缺点

召开末次会议

- ◆ 现场评估之后，评估组长应该主持召开末次会议，有评估小组、受评估方领导和各相关部门负责人共同参加。
- ◆ 末次会议的任务在于：向受评估方介绍评估的情况；报告评估发现（重大风险点）和评估结论；提出后续工作的建议（纠正措施等）；结束现场评估。



末次会议议程及内容



Summary of The Class

- 风险及风险的处置方式
- 风险计算模型

